



Allianz Sigorta A.Ş.
25.09.2026

YEREL AĞ ÜZERİNDEN WEB UYGULAMA GÜVENLİK DENETİM RAPORU Sürüm 1.0

Testler 25.09.2026 tarihinde gerçekleştirilmiştir.

Bu belge Allianz Sigorta A.Ş. kurumuna ait GİZLİ bilgiler içermektedir ve yetkili kişiler haricinde okunması yasaktır.
Bu belge elinize yetkisiz bir şekilde ulaşırsa lütfen pentest@cyberwise.com.tr adresine bildiriniz.



25.09.2026

Allianz Sigorta A.Ş. Yetkililerinin Dikkatine,

Allianz Sigorta A.Ş. bilgi sistemleri altyapısı içinde bulunan sistemlerin güvenliğine ilişkin olarak yerel ağ üzerinden denetim çalışmasını tamamladık.

Çalışmayı gerçekleştirirken kurumunuzun sağladığı yardımlar ve göstermiş olduğunuz anlayış için teşekkür ederiz. Rapordaki sonuçlar ve bulgular hakkında daha fazla bilgi edinmek isterseniz Cyberwise Güvenlik Denetim ekibi ile bağlantıya geçebilirsiniz.

Bu rapor sadece Allianz Sigorta A.Ş. yetkililerinin bilgisine sunulmuştur.

Saygılarımızla,
Cyberwise Siber Güvenlik Ticaret A.Ş.



İÇİNDEKİLER

YASAL SORUMLULUKLAR	3
1. YÖNETİCİ ÖZETİ	4
1.1 – ÖNSÖZ.....	4
1.2 – KAPSAM	4
1.3 – TARAMA METODU.....	5
1.4 – RİSK DEĞERLENDİRMESİ	5
1.4.1 – RİSK DEĞERLENDİRME YÖNTEMİ	5
1.4.2 – ETKİ AÇIKLAMALARI	6
1.4.3 – KÖK NEDEN AÇIKLAMALARI	6
1.4.4 – RAPOR TABLOSUNUN KULLANIMI	7
1.5 – ÖZET SONUÇLAR.....	8
1.6 – GENEL DEĞERLENDİRME	10
2. DETAYLI SIZMA TESTİ SONUÇLARI	11
2.1 - Detaylı Uygulama Hata Mesajları XSS Problemine Neden Oluyor	11
2.2 - Yetkisiz Erişim Yapılabilen Uygulamalar ve Servisler	13
2.3 - Swagger API Dokümantasyon Sayfalarına Erişim	17
2.4 - Web Sunucu Default Hata Mesajları.....	18
3. EKLER.....	20
3.1 – İLETİŞİM BİLGİLERİ	20
3.2 – TAKİP EDİLEN YÖNTEMLER	20
3.2.1 – İNTERNET GÜVENLİK DENETLEMESİ YÖNTEMİ	21
3.2.2 – WEB UYGULAMASI GÜVENLİK DENETLEMESİ YÖNTEMİ	22



YASAL SORUMLULUKLAR

İşbu rapor Allianz Sigorta A.Ş. için hazırlanmıştır. İşbu Rapor Müşteri'nin Sistem'inde yapılan zafiyet analiz test sonuçları esas alınarak hazırlanmıştır. Zafiyet analiz testleri 25.09.2026 tarihinde gerçekleştirilmiştir.

1- İşbu Rapor içeriği gizli olup Cyberwise Siber Güvenlik Ticaret A.Ş.'nin yazılı mutabakatı olmadan üçüncü şahıslara basılı (hardcopy), elektronik ortamda (softcopy) ya da herhangi başka bir şekilde içeriğinin bir kısmı ya da bir bütünü olarak transfer edilemez, çoğaltılamaz, paylaşılamaz veya beyan edilemez.

2- Raporlar tarama süresi içinde varlığı bilinen veya Cyberwise Siber Güvenlik Ticaret A.Ş. tarafından tespit edilen güvenlik açıklarını içermektedir. Cyberwise Siber Güvenlik Ticaret A.Ş. her ne kadar içeriğin doğruluğu ve hassasiyeti için maksimum çaba gösterdiyse de Rapora ait muhtemel eksikliklerden dolayı hiçbir şekilde sorumlu tutulamaz. Tarama işlemi bittikten Rapor teslim edilene kadar geçen süre içerisinde çıkabilecek yeni güvenlik açıklarına dair eksikliklerden dolayı da Cyberwise Siber Güvenlik Ticaret A.Ş. sorumlu tutulamaz.

Raporda verilen bilgiler, "olduğu gibi", "mevcut olduğu şekilde" sağlanmaktadır. Cyberwise Siber Güvenlik Ticaret A.Ş. bu bilgilerin doğruluklarını, yeterliliklerini ve eksiksizliklerini garanti etmemekte ve bu bilgilerdeki hatalar ya da eksiklikler nedeniyle sorumluluğu, açık bir şekilde reddetmektedir. Bu bilgilerle üçüncü şahısların haklarının ihlal edilmemesi; mülkiyet ve belirli bir amaç için uygunluk ilişkin garantiler dahil ancak bunlarla sınırlı kalmamak kaydıyla, zımnen, açıkça ya da yasal olarak hiçbir garanti vermemektedir.

3- Raporlar bilgilendirme amaçlı olup içinde yer alan çözüm önerilerinin uygulanması sebebi ile çıkabilecek sorunlardan Cyberwise Siber Güvenlik Ticaret A.Ş. sorumlu değildir. Önerilerde sunulan değişiklikler gerçekleştirilmeden önce mutlaka konu hakkında destek alınan firmalara veya uzman danışmanlara görüşleri sorulmalıdır. Çözüm önerilerinin gerçekleştirilmesi kararı tamamen Müşterinin keyfiyetindedir.

4- Müşteri, Cyberwise Siber Güvenlik Ticaret A.Ş.'ne işbu Raporu hazırlamak için zafiyet analiz testlerini gerçekleştirmek üzere izin vermiştir.

5- Zafiyet analiz testleri sırasında, gerçekleştirilen testlerin üçüncü şahıslar tarafından dinlenmesi veya gözlenmesi sonucunda ortaya çıkan güvenlik açıkları ve bunun sonucunda ileride ortaya çıkabilecek kayıplardan Cyberwise Siber Güvenlik Ticaret A.Ş. sorumlu tutulamaz.

6- Rapor içinde yer alan test sonuçları Müşteri veya kullanılan uygulamalar hakkında kritik bilgiler içerebilir. Dolayısı ile Raporun dağıtılması konusunda gerekli hassasiyetin Müşteri tarafında da gösterilmesi gerekmektedir. Raporun kaybolması veya 3. şahıslar tarafından ele geçirilmesi sebebi ile kritik bilgilerin elde edilmesi durumunda doğacak kayıplardan Cyberwise Siber Güvenlik Ticaret A.Ş. sorumlu tutulamaz.

7- Sonuç raporu TSE standartları gereği aksi belirtilmedikçe, kapsam formunda belirtilen süre boyunca (90 gün) Cyberwise Siber Güvenlik Ticaret A.Ş. sistemlerinde saklanacaktır. Sürenin bitişine müteakip rapor Cyberwise Siber Güvenlik Ticaret A.Ş. sistemlerinde geri döndürülemeyecek şekilde imha edilecektir. Bunun sonucunda ileride ortaya çıkabilecek kayıplardan Cyberwise Siber Güvenlik Ticaret A.Ş. sorumlu tutulamaz.



1. YÖNETİCİ ÖZETİ

1.1 – ÖNSÖZ

Cyberwise Siber Güvenlik Ticaret A.Ş. güvenlik denetim ekibi olarak Allianz Sigorta A.Ş. yetkililerinin isteği doğrultusunda, Yerel ağ üzerinden kapsam bölümünde detayı sunulan web/api uygulamalarına yönelik saldırı ve sızma testlerini 25.09.2026 tarihinde gerçekleştirdik. Bunu yaparken esas amacımız, test edilen sunucular ve uygulamalar üzerinde bulunabilecek muhtemel güvenlik açıklarını ve yapılandırma hatalarını kötü niyetli saldırganlardan önce ortaya çıkartmak ve gerekli önlemlerin alınmasına katkı sağlamaktır.

İnternet üzerinden gerçekleştirilen bu testler, sistemler hakkında herhangi bir detaylı bilgisi olmayan sıradan kullanıcı hakları ile gerçekleştirilmiştir. Dolayısı ile özel uygulamalara erişim yetkisi bulunan kullanıcılar tarafından gerçekleştirilebilecek saldırılar ve bunlardan doğacak riskler bu rapor kapsamında yer almamaktadır.

Güvenlik testleri, çalışan sistemler üzerinde olumsuz bir etki yaratmayacak ve zarar vermeyecek şekilde gerçekleştirilmiştir. Bu nedenle sistemler üzerinde olumsuz etki oluşturabilecek bazı kontroller yapılmamış veya sınırlı bir şekilde gerçekleştirilmiştir. Ancak sisteme sızmak veya ele geçirmek isteyen bir saldırgan, sunucuya vereceği zararı düşünmeyecektir. Bu nedenle yeterince donanımlı, kaynağa ve zamana sahip saldırganların, bu raporda belirtilenden daha fazla güvenlik açığını bulup, kötüye kullanması azımsanamayacak bir olasılık olduğu için, rapordaki açıkların ivedilikle yamanması kadar, bu tür açıkları azaltacak, kapsamlı bir kurumsal bilgi güvenliği stratejisi uygulanması da önemlidir.

Rapor, bulunan her güvenlik açığının risk derecesini, açık hakkında açıklamaları, daha detaylı bilgi bulabileceğiniz bağlantıları, güvenlik açığının nasıl kapatılabileceği hakkında gerekli bilgiyi, açığın nasıl kötüye kullanılabileceği hakkında örnekleri ve Cyberwise Siber Güvenlik Ticaret A.Ş. firmasının yorum ve önerilerini içermektedir.

Rapor, okuyucunun TCP/IP ve kullanılan teknoloji hakkında temel bilgilere sahip olduğu düşünülerek hazırlanmıştır. Bu sebeple raporlarda kullanılan terimler ile ilgili her hangi bir açıklama yapılmayacaktır.

1.2 – KAPSAM

Raporda detayları sunulan çalışmanın kapsamı aşağıda belirtilmiştir.

Web Uygulaması Güvenlik Denetimi: İnternet üzerinden erişilebilen web uygulamaları OWASP standartlarına uygun bir şekilde kontrol edilmiştir. Tüm kontroller sıradan kullanıcı hakları ile gerçekleştirilmiştir. Bu testler esnasında, test edilen sunucular tarafından verilen hizmetlerin sekteye uğratılmaması amacıyla Denial of Service (DoS) saldırıları ve bellek taşması tipi zayıflıkları kullanan saldırılar yapılmamıştır. İstenmeyen hesap kilitlenmelerini engellemek için parola tahmin saldırıları sınırlı bir şekilde gerçekleştirilmiştir. Aşağıda denetleme çalışması kapsamında kontrol edilen web sunucuların ve uygulamaların listesi yer almaktadır.

- <https://int-sc-uat-elementer.allianz.com.tr/sbm-declaration-services/api/v1/declarations/upload>
- <https://int-sc-uat-elementer.allianz.com.tr/sbm-declaration-services/api/v1/declarations/send>
- <https://int-sc-uat-elementer.allianz.com.tr/sbm-declaration-services/api/v1/declarations/query>
- <https://int-sc-uat-elementer.allianz.com.tr/sbm-declaration-services/api/v1/declarations/PENTEST1402-01-PUT>
- <https://int-sc-uat-elementer.allianz.com.tr/sbm-declaration-services/api/v1/declarations/PENTEST1402-01>



1.3 – TARAMA METODU

Saldırı ve sızma testleri, kullanılan sunucu, uygulama yapısı veya teknolojisi hakkında, firmadan en az bilgi temin edilerek gerçekleştirilmiştir. Testler gerçekleştirilirken aşağıda verilen IP adresleri kullanılmış ve bu IP adresinden gelen isteklerin, kurum koruma sistemleri tarafından sürekli olarak bloklanmasını engelleyici ek ayrıcalıklar tanımlanmıştır.

- 10.70.238.86

1.4 – RİSK DEĞERLENDİRMESİ

Bulunan her güvenlik açığı veya sistemler hakkında bilgi toplamaya yarayan her türlü bilgi sızıntısı, kurumun bilgi sistemlerinin güvenliği için oluşturduğu tehdit açısından önem sırasına göre değerlendirilmelidir. Yapılan çalışma sonucunda ortaya çıkarılan güvenlik açıkları, aşağıda anlatılan risk değerlendirmesi yöntem ve kıstaslarına göre sınıflandırılmıştır.

1.4.1 – RİSK DEĞERLENDİRME YÖNTEMİ

Bulunan güvenlik açıkları, önem seviyesi Acil, Kritik, Yüksek, Orta, Düşük olmak üzere 1 ve 5 arası puanlandırılmıştır. Bu puanlar bulunan veya bulunduğu şüphelenilen açığın, kurum için oluşturduğu tehdidin derecesini göstermektedir. Elde edilen açıktan yararlanmanın kolaylığı, oluşturduğu riskin büyüklüğü, açıktan yararlanmaya yardımcı olacak yayınlanmış bilgilerin bulunması tehlike seviyesini artıracaktır.

Raporda yer alan her bir güvenlik açığı, yukarıda anlatılan önem seviyelerinde birine atanır. Buna göre tanımlı önem seviyelerinin açıklamaları aşağıdaki tablodan incelenebilir.

Tespit Edilen Güvenlik Açığı: Güvenlik açığının analiz edilen sistemde kesinlikle bulunduğunu ve belirli bir risk oluşturduğunu ifade eder. Bu risk, bilgi yayınlamadan, tüm sistemin ele geçirilmesine kadar değişebilir ve önem seviyesi aşağıdaki tabloya göre değerlendirilir.

ÖNEM SEVİYESİ	
5 (Acil)	Bu seviyedeki güvenlik açıkları saldırganlar tarafından kolaylıkla kötüye kullanılabilir ve bütün sunucunun ele geçirilmesiyle ve dolayısıyla tüm ağın güvenliğinin tehlikeye atılmasıyla sonuçlanabilir.
4 (Kritik)	Bu seviyedeki güvenlik açıkları saldırganlar tarafından genellikle kötüye kullanılabilir ve bütün sunucunun ele geçirilmesiyle veya en azından hassas bilgilerin açığa çıkmasıyla sonuçlanabilir.
3 (Yüksek)	Bu seviyedeki güvenlik açıkları saldırganlar tarafından kötüye kullanılabilir ve sunucudaki güvenlik ve sistem yapılandırması bilgilerinin ele geçirilmesi, hizmet kesintisi ile sonuçlanabilir.
2 (Orta)	Bu seviyedeki güvenlik açıkları saldırganların hassas sistem, uygulama ve program sürüm bilgilerini ele geçirmesine neden olabilir.
1 (Düşük)	Bu seviyedeki güvenlik açıkları saldırganların sistemin basit bilgilerini (portlar, servisler, sürüm vb.) ele geçirilmesine neden olabilir.



1.4.2 – ETKİ AÇIKLAMALARI

Rapor içinde belirtilen zafiyet etkilerinin detaylı açıklamaları aşağıdaki tabloda incelemenize sunulmuştur.

ETKİ	AÇIKLAMA
Uzaktan Kod Çalıştırma	Saldırganların hedef sistem üzerinde istedikleri kodları ve komutları çalıştırmaya olanak tanıyan, genellikle sistemin ele geçirilmesine neden olan zafiyetlerdir.
Yetkisiz Erişim	İlgili bileşene yetkisiz kullanıcıların erişebileceği türden bulguları ifade eder. Parola korumasız alanlar, ya da zayıf kimlik yönetimi yapılan bileşenlerde görülür.
Yerel Ağ Sızma	Kurum ağları içinde Internet üzerinden direkt erişim imkânı olmayan sistemlere bağlantı yapma veya istek yollama imkânı tanıyabilecek zafiyetlerdir.
Hak Yükseltme	Kullanıcıların mevcut hakları dışında, daha üst seviyede yetki gerektiren işlemleri yapmasına olanak tanıyan zafiyetlerdir.
Finansal Zarar	Uygulama, test edilen bileşen, tasarlanan iş akışı veya hatalı entegrasyonlar nedeni ile para kaybına uğranmasına neden olabilecek zafiyetlerdir.
Oturum Bilgilerini Çalma	Uygulamaya bağlanan diğer kullanıcılara ait oturum bilgilerini ele geçirmeye olanak tanıyan zafiyetlerdir.
Hizmet Kesintisi Saldırıları	Hedef sistemi, uygulamayı veya kurum alt yapısını kısmen veya tamamen erişilemez duruma getirmeye olanak tanıyacak zafiyetlerdir.
MITM Saldırıları	Ağ üzerinde araya girerek, iletilen trafiğin incelenmesine ve değiştirilmesine olanak tanıyan bulgulardır.
Parola Tahmin Saldırıları	Deneme-Yanılma yöntemi ile parola tahmin saldırıları gerçekleştirilmesine imkân tanıyacak bulgulardır.
Phishing ve SPAM	Phishing veya SPAM içerik yollanmasına olanak tanıyacak e-posta sunucu veya uygulama problemleridir.
Bilgi Açığa Çıkarma	Hedef sistem, uygulama veya altyapı hakkında önemli bilgiler içeren bulgulardır.

1.4.3 – KÖK NEDEN AÇIKLAMALARI

Raporlanan zafiyetlerin temel olarak hangi eksikliklerden kaynaklandığı ve hangi konularda çalışma yapılarak bu eksikliklerin kısa sürede giderilebileceğini belirlemek üzere, kök neden gruplaması gerçekleştirilmektedir. Eksik alanlarda yapılacak iyileştirmeler ve süreç düzenlemeleri ile benzer sorunların ileride ortaya çıkmasının önüne geçilebilir.

KÖK NEDEN	AÇIKLAMA
Yama Yönetimi	Belirlenen problemin mevcut yamaların yüklenmesindeki eksikliklerden kaynaklandığı durumu ifade etmektedir.
Yapılandırma Yönetimi	Belirlenen problemin hatalı veya eksik yapılmış yapılandırma ayarlarından, güvenli olmayan tasarımlardan kaynaklandığı durumu ifade etmektedir.
Parola ve Hesap Yönetimi	Belirlenen problemin mevcut parola ve hesap yönetimindeki sorunlardan kaynaklandığı durumu ifade etmektedir.
Güvenli Yazılım Geliştirme Süreci	Kurum içindeki veya kurumun hizmet aldığı 3.parti firmaların yazılım ekipleri tarafından geliştirilen uygulamalarda S-SDLC süreçlerinin eksik işletilmesi nedeni ile ortaya çıkan ve henüz çözüm getirilememiş problemleri ifade etmektedir.
Bilgi Güvenli Farkındalığı	Kurum çalışanlarının bilgi güvenliği farkındalığı eksikliğinden dolayı ortaya çıkabilecek problemleri ifade etmektedir.
Kapasite Yönetimi	Kurum mevcut sistemlerinde tespit edilen performans ve kapasite sorunlarını ifade etmektedir.
Sistem ve Altyapı Yönetimi	Kurum bilgi teknolojileri alt yapısı ve bu yapının yönetimi sırasında tespit edilen sıkıntıları ifade etmektedir.



1.4.4 – RAPOR TABLOSUNUN KULLANIMI

Raporda yer alan bulgular ile ilgili genel detaylar aşağıda yer alan örnek tablo ile açıklanmıştır. Bulgu ile ilgili genel detaylar bölümünde; bulgu adı, kategorisi, etkisi, kök nedeni, risk seviyesi açıklaması ve port bilgileri yer almaktadır.

Bulgu ile ilgili genel detaylar		Risk seviyesi
Bulgu açıklaması	3.2 – Captcha Replay Güvenlik Problemleri Kategori: Web Uygulama Güvenlik Problemleri Etki: Hizmet Kesintisi Saldırıları Kök Neden: Güvenli Yazılım Geliştirme Süreci Risk: Yüksek Port: 80/TCP	3
	10.0.0.1	Bulgunun tespit edildiği varlıklar listesi
	Açıklama: CAPTCHA (Completely Automated Public Turing test to tell Computers and Humans Apart) web uygulamalarının, kendilerine yollanan verilerin, bilgisayar tarafından gönderilmediğinden emin olmak için kullandıkları bir sistemdir. Özellikle - Login, parola sıfırlama uygulamalarında deneme-yanılma yolu ile kullanıcı adı ve parola tespitinin engellenmesi - E-Posta, SMS vb sistemler ile mesaj yollamak için kullanılan uygulamalarda çok sayıda GET/POST isteği ile DoS, SPAM ve Phishing saldırısı gerçekleştirilmesinin engellenmesi - Hesap oluşturma işlemini gerçekleştiren uygulamalarda otomatik hesap oluşturma işleminin engellenmesi - Bilgi girişi yapılmasına izin veren uygulamalarda çok sayıda verinin sisteme otomatik olarak yollanmasını ve sistem kaynaklarını tüketmesini engellemek - Sorgulama yapılmasına izin veren uygulamalarda çok sayıda bilginin otomatik bir şekilde elde edilmesini engellemek için kullanılabilir. Gerçekleştirilen testlerde sunucuya uygulamalar aracılığı ile toplu olarak veri yollanmasını engellemek amacı ile değişik uygulamaların Captcha koruması kullandığı görülmektedir. Ancak ilgili mekanizmanın geçerli bir anahtar değer bilgisi ve captcha tarafından üretilen değer girildiği parametre değiştirilmediği müddetçe devre dışı bırakılabildiği belirlenmiştir. Çözüm/Öneri: Kullanılan Captcha uygulamasının gözen geçirilmesi yararlı olacaktır. Üretilen Captcha değeri sadece bir defa geçerli olmalıdır. Aşağıdaki gibi örnek bir kodun captcha doğrulaması için kullanılması bu tarz saldırıların önüne geçilmesine yardımcı olacaktır.	
Bulgu çözüm önerisi	<pre>if(Session["captcha"]!=null) { if(Session["captcha"]==Request["captcha"]) { Session["captcha"]=null; return true; } else { Session["captcha"]=null; return false; } }</pre>	



1.5 – ÖZET SONUÇLAR

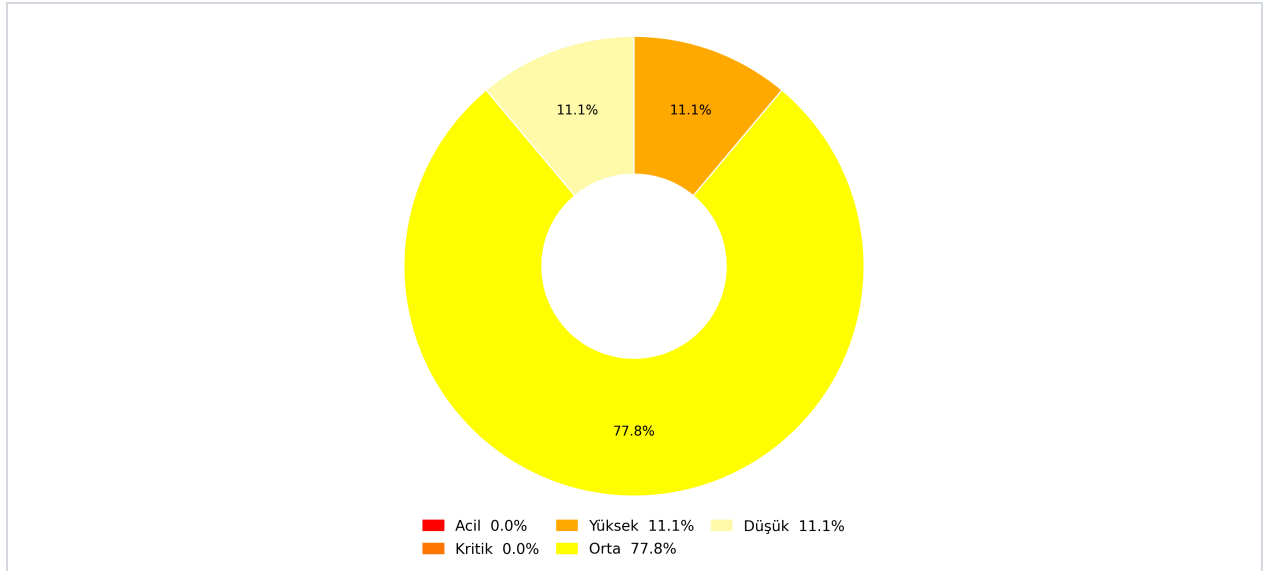
1.5.1 – Zafiyet Dağılımı

Gerçekleştirilen çalışmalar neticesinde 4 farklı bulgu altında 9 zafiyet raporlanmış olup, bu bulguların tespit edildiği bileşenlere göre dağılımı aşağıda incelemenize sunulmuştur.

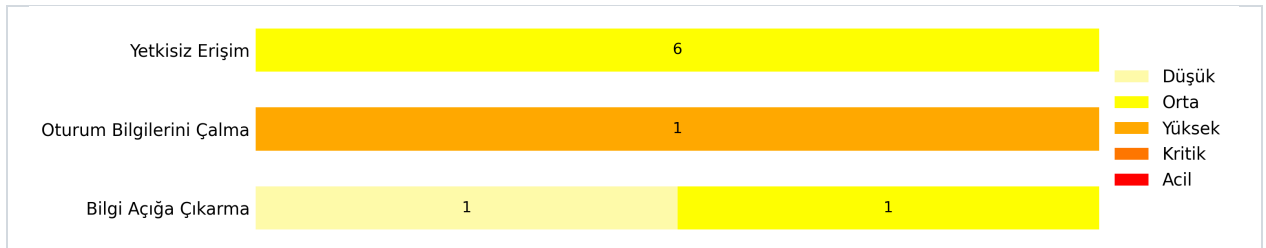
No	BULGU	ZAFİYET SAYISI	RİSK ETKİSİ	RİSK SKORU
2.1	Detaylı Uygulama Hata Mesajları XSS Problemine Neden Oluyor	1	Oturum Bilgilerini Çalma	3 (Yüksek)
2.2	Yetkisiz Erişim Yapılabilen Uygulamalar ve Servisler	6	Yetkisiz Erişim	2 (Orta)
2.3	Swagger API Dokümantasyon Sayfalarına Erişim	1	Bilgi Açığa Çıkarma	2 (Orta)
2.4	Web Sunucu Default Hata Mesajları	1	Bilgi Açığa Çıkarma	1 (Düşük)

1.5.2 – Tespit Edilen Güvenlik Açıklarının Risk Seviyelerine Göre Dağılımı

Testler neticesinde raporlanan toplam 9 adet problemin risklere göre dağılımı aşağıdaki grafikte sunulmuştur.



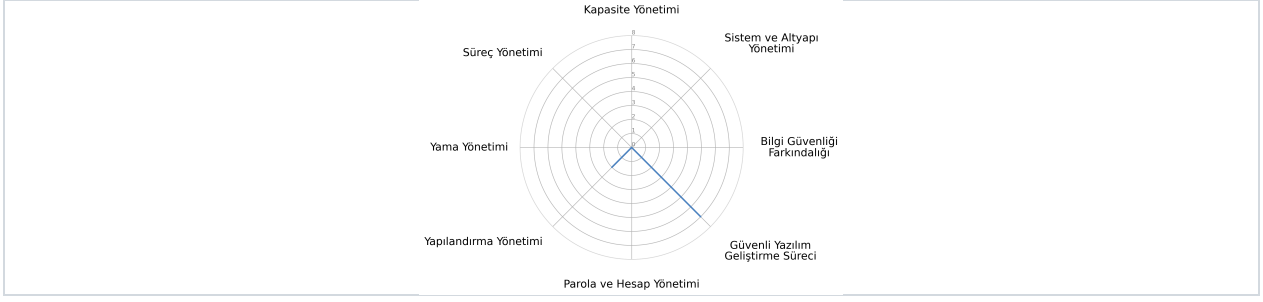
1.5.3 – Raporlanan Zafiyetlerin Etkisine Göre Dağılımı





1.5.4 – Kök Nedenlerine Göre Problemlerin Dağılımı

Raporlanan zafiyetlerin temel olarak hangi sorunlardan kaynaklandığı aşağıda incelemenize sunulmuştur.



Mavi renkli grafik tüm bulguların, kırmızı renkli grafik ise sadece Acil ve Kritik risk seviyesindeki bulguların kök nedenlerini göstermektedir. En fazla problemin bulunduğu alanlarda iyileştirme yapılarak, ileride benzer sorunlar ile karşılaşılması ihtimali azaltılabilir.

1.5.5 – Tespit Edilen Güvenlik Açıklarının Risk Kategorilerine Göre Dağılımı

Raporlanan 9 adet zafiyetin risk seviye ve kategorilerine göre dağılımı aşağıdaki tabloda incelemenize sunulmuştur. Tablo incelendiği zaman önem arz eden problemlerin genellikle web uygulamaları ve web sunucu yapılandırma hatalarından kaynaklandığı göze çarpmaktadır.

Risk Kategorileri	Acil	Kritik	Yüksek	Orta	Düşük	Toplam
Web Sunucu Yapılandırma Hatası ve Güvenlik Problemleri	-	-	-	1	1	2
Web Uygulama Güvenlik Problemleri	-	-	1	6	-	7
Toplam	-	-	1	7	1	9



1.6 – GENEL DEĞERLENDİRME

Toplam dört bulgu tespit edilmiştir; bunların bir tanesi yüksek, ikisi orta ve bir tanesi düşük risk seviyesindedir. Yüksek seviyedeki bulgu, detaylı uygulama hata mesajlarının XSS (Cross-Site Scripting) sorununa yol açmasıdır. Bu durum, saldırganın zararlı script enjekte etmesine ve kullanıcıların oturum bilgilerini çalmasına, veri sızıntısına, sistemin yetkisiz manipülasyonuna ve hizmet kesintilerine yol açabilir.

Orta seviyeli iki bulgu, Swagger API dokümantasyon sayfalarına yetkisiz erişim ve yetkisiz erişilebilen uygulama ve servislerin varlığıdır. Bu eksiklikler tek başına kritik sonuç doğurmasa da saldırı yüzeyini genişleterek kötü niyetli aktörlerin daha derin penetrasyon sağlamasına zemin oluşturur.

Düşük seviyeli bulgu, web sunucusunun varsayılan hata mesajlarıdır. Bu mesajlar, sistem hakkında bilgi ifşası riski taşır; tek başına ciddi tehdit oluşturmaz ancak diğer açıklarla birleştirildiğinde riski artırabilir.

Bulguların önceliklendirilerek ele alınması tavsiye edilmektedir. Öncelikle yüksek riskli XSS hatası hızlıca giderilmeli, ardından orta seviyeli API ve servis erişim eksiklikleri sistematik olarak kapatılmalı; son olarak düşük seviyeli bilgi ifşası unsurları da iyileştirilmelidir. Bu adımlar, projenin genel güvenlik seviyesini artıracak ve yasal uyumluluk ile kullanıcı güveni açısından önemli bir katkı sağlayacaktır.

[illegible]

0Yybnu0mzQxy0x-g0|!Mvm0YN-0UQ?0a0Uñ·0éiÄ,úké»-/'İm0p'0'~&çüGW0000H#?9"É2ÜÜ0\0DYF{JN0<X 0İ0000÷^,0006:0000&ÜÜ00·r{0ÈÜİ0
 t~Ü?iFçÄÜ0İ±50%;*e:CNg:003çYÄÉ/pN0'0MM0;00000V0VeÄç1A04wä±ü0?%×0²¹~V -ÿçÜvU0H0MÉÉä0<%É×j0R00âU0C0Dvz 060!|dú000W0NàM<{q(yîF{,É00'0%×»PE\İ-0?ÖÜv9'Ü-0İ7\²0R0<0YßYà3P
 ^2X¥=, xXÆi0~n0=²0E0m0Up[0,00M0öAr%;_Épßpury0İ{ieÜGÉBæ040ë0JcêÉúá·3GÇp0x_0YhÜİ0È0J10İ000æ0|çU0J00yHK«É+ä¹Uæ(é0Q1C1 0X0p009j;ì""Q0~0ä00Y0wI
 è#,È%V""',{w0Mâ0èpÆEÜx»F0,ôJÄ×İ0X0ç?vcj~"0ZF-á¹00VFDÉ""mÉ
 070
 iÆ@|!|FC*R;0ÈÜ0ð0wB:ð00"ä0"èx mcúÄ#00@ ,1=i00*#
 à0 !N@Ü
 P"ý00t00i¹·Açp0ñ!zç÷|N0çİ00Ü0~
 juÈð0@yynPzÈ00jDhð)00ð0ÄJ
 "00 ä(c\$S@0ç0+000sJ0³Uì ü0000EapDİäİ4d000ç'5b1{qPRZpßİh0Qip`i0Ä,0³ÜÉ}ÄÉ0Nd0ç0ñxMZB}» '%00 T0IÄ'%"">ç\À|(0pý0Ü2>Äüè?ðÈ0Ä0A-Tw0tm
 H0é22h0²*b00İjßn!M»|3b0ÜAè-çÜznw0İ0~Ä÷ÉpFNÄß3 80{ý'000f0è:Q00ä;0xÿY.0tç°9èç>Ü70i»02"0>Ü
 0A(ß|0è0é0çÄ"0tÆN'É³000'ç4"0ó[b"0000
 0Hh ""00XİÉ9BÈE-\$0I»Èx-9b\$E£c 1*ĐÍZÄIZİ0p-Ä0 0"A;·ðQ240EH0Háá0c?hv0iÄfÄ1QÉ9â0M,800è#v`6XI0×00/n0
 Ræ0Ä
 İÉ0ÆA0Y""|0a ÄnDáæD%00.Vp0bÄÜNè00V»Y000İ0è00"N8G"0·ç%óí1na1uY)²B
 ð0K÷=²TeiWýİÜÄ0000±0xµÆ,00kLY000i_0yn0P=0á"ÉÉ00 çİ0İ;ÿæNËspeý÷Üü³0ÈÉİµ+`00áigàà;z000ðè\ð3úr70wmpeu~¹0\$%/Dýmý/ 000+ ý60ý
 %\òq`0pS÷0+0rİ\$;nÄ0]0ð³0ÈAAZÉI<æ00µ0]ü0yp0kÄ0çYçPK?Äp8]Nz}0w \$ bruno-pentest-2014-02.json
 <²LYPK?Äp8]MÚP0÷\$ »PEN-TEST-REHBERI.md
 è0%0LYPK?Ép8]ÈtÆÉ}\$ pentest-2014-02-yukleme.xlxs
 äµß,LYPK?!
 -----a9a1c5f82172a8f7aef745ec--

HTTP CEVAP

```
HTTP/1.1 400 Bad Request
content-type: application/json
date: Fri, 25 Sep 2026 08:57:26 GMT
Content-Length: 236
```

```
{
  "result": false,
  "status": 400,
  "error": {
    "timestamp": "2026-09-25T11:57:26.756101823",
    "reasons": [
      {
        "code": "ALZ-VALIDATION",
        "message": "Sadecce .xlsx dosyasÄ± yÃ¼klenebilir. Gelen: PEN TEST 24.09.2026.zipd7x96<script>alert(1)</script>dbvm7"
      }
    ]
  }
}
```

Çözüm/Öneri: Söz konusu problemler genellikle web ya da uygulama sunucusu kaynaklı olarak ortaya çıkmaktadır. Bu nedenle sorunun tespit edildiği web/uygulama sunucusunun güncellenmesi ve detaylı hata mesajlarının gösteriminin kapatılması ile problem ortadan kaldırılabilir.

2.2 - Yetkisiz Erişim Yapılabilen Uygulamalar ve Servisler

Kategori: Web Uygulama Güvenlik Problemleri
Etki: Yetkisiz Erişim
Kök Neden: Güvenli Yazılım Geliştirme Süreci
CVSSv3 Skoru: 7.5
Risk: Orta
Port: 443/TCP

int-sc-uat-elementer.allianz.com.tr - 10.70.52.91

Açıklama: Gerçekleştirilen kontrollerde kimlik doğrulaması yapıldıktan sonra erişilmesi gereken bazı korumalı sayfalara, uygulamalara, api uç noktalarına veya servislere direkt erişimin mümkün olduğu ve yetkilendirme işleminin bu uygulamalar için gerçekleştirilmediği görülmüştür. Bu durum yetkisiz kullanıcılara uygulama ile sağlanan bilgilere erişme veya değiştirme imkanı tanıyabilir.

No	Uygulama	Açıklama
----	----------	----------



1	/sbm-declaration-services/api/v1/declarations/processes	Verilen postman collection dışında erişim sağlanmış ve herhangi bir oturum anahtarı bulunmadan erişim sağlanabilmektedir. Erişimler için kısıtlama olduğundan emin olunması amacıyla bulgu olarak değerlendirilmiştir.
2	/sbm-declaration-services/api/v1/declarations/upload	Herhangi bir oturum anahtarı bulunmadan erişim sağlanabilmektedir. Erişimler için kısıtlama olduğundan emin olunması amacıyla bulgu olarak değerlendirilmiştir.
3	/sbm-declaration-services/api/v1/declarations/send	Herhangi bir oturum anahtarı bulunmadan erişim sağlanabilmektedir. Erişimler için kısıtlama olduğundan emin olunması amacıyla bulgu olarak değerlendirilmiştir.
4	/sbm-declaration-services/api/v1/declarations/query	Herhangi bir oturum anahtarı bulunmadan erişim sağlanabilmektedir. Erişimler için kısıtlama olduğundan emin olunması amacıyla bulgu olarak değerlendirilmiştir.
5	/sbm-declaration-services/api/v1/declarations/PENTEST1402-01	Herhangi bir oturum anahtarı bulunmadan erişim sağlanabilmektedir. Erişimler için kısıtlama olduğundan emin olunması amacıyla bulgu olarak değerlendirilmiştir.
6	/sbm-declaration-services/api/v1/declarations/PENTEST1402-01 - GET	Herhangi bir oturum anahtarı bulunmadan erişim sağlanabilmektedir. Erişimler için kısıtlama olduğundan emin olunması amacıyla bulgu olarak değerlendirilmiştir.

Uygulama #1: Paylaşılan postman collection dışında erişim sağlanmış ve herhangi bir oturum anahtarı bulunmadan erişim sağlanabilmektedir. Erişimler için kısıtlama olduğundan emin olunması amacıyla bulgu olarak değerlendirilmiştir.

HTTP İSTEK

GET /sbm-declaration-services/api/v1/declarations/processes HTTP/1.1
Host: int-sc-uat-elementer.allianz.com.tr:443
Connection: close

HTTP CEVAP

HTTP/1.1 200 OK
content-type: application/json
date: Fri, 25 Sep 2026 12:54:15 GMT
Content-Length: 12720

{ "result": true, "status": 200, "data": { "content": [{ "id": 44, "declarationYear": 2012, "declarationMonth": 1, "cityCode": 2, "districtCode": 1105, "sbmFileNo": "PENTEST1201-06", "movableType": "GAYRIMENKUL", "status": "NEW", "paymentDate": "2012-02-20", "receivedPremiumAmount": 14500, "cancelledPremiumAmount": 300, "taxAmount": 1420, "taxPremiumAmount": 14200, "taxRatio": 10, "dateSent": null, "errorDetails": null }, { "id": 43, "declarationYear": 2012, "declarationMonth": 1, "cityCode": 2, "districtCode": 1105, "sbmFileNo": "PENTEST1201-06", "movableType": "MENKUL", "status": "NEW", "paymentDate": "2012-02-20", "receivedPr***

Uygulama #2:

HTTP İSTEK

POST /sbm-declaration-services/api/v1/declarations/upload HTTP/1.1
Host: int-sc-uat-elementer.allianz.com.tr
Connection: close
Content-Length: 10228
X-Requester-Id-No: 12345678901
User-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS X 10_15_7) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/153.0.0.0 Safari/537.36
Content-Type: multipart/form-data; boundary=---WebKitFormBoundaryRJNTDkiGYnVhCE1l
X-User-Name: allianz
X-Requester-Id-Type: 1
Origin: https://int-sc-uat-elementer.allianz.com.tr
Referer: https://int-sc-uat-elementer.allianz.com.tr/sbm-declaration-services/swagger-ui/index.html
Cookie: ***



```
-----WebKitFormBoundaryRJNTDkiGYnVhCEi1
Content-Disposition: form-data; name="file"; filename="../../../pentest-2012-01-yukleme-2.xlsx"
Content-Type: application/vnd.openxmlformats-officedocument.spreadsheetml.sheet***
```

HTTP CEVAP

```
HTTP/1.1 200 OK
content-type: application/json
date: Fri, 25 Sep 2026 12:48:27 GMT
Content-Length: 202
```

```
{"result":true,"status":200,"data":{"sourceFileName":"../../../../pentest-2012-01-yukleme-2.xlsx","totalRows":12,"inserted":0,"updated":0,"insertedFileNos":[],"updatedFileNos":[],"failed":0,"errors":[]}}
```

Uygulama #3:

HTTP İSTEK

```
POST /sbm-declaration-services/api/v1/declarations/send HTTP/1.1
Content-Type: application/json
User-Agent: bruno-runtime/4.2.0
X-User-Name: allianz
Content-Length: 32
Host: int-sc-uat-elementer.allianz.com.tr
Connection: keep-alive
```

```
{
  "year": 2014,
  "month": 3
}
```

HTTP CEVAP

```
HTTP/1.1 200 OK
content-type: application/json
date: Fri, 25 Sep 2026 08:41:11 GMT
Content-Length: 97
```

```
{"result":true,"status":200,"data":{"totalGroups":0,"successCount":0,"failCount":0,"results":[]}}
```

Uygulama #4:

HTTP İSTEK

```
POST /sbm-declaration-services/api/v1/declarations/query HTTP/1.1
Content-Type: application/json
User-Agent: bruno-runtime/4.2.0
X-User-Name: allianz
Content-Length: 51
Host: int-sc-uat-elementer.allianz.com.tr
Connection: close
```

```
{
  "year": "2014",
  "month": "2",
}
```



"

HTTP CEVAP

HTTP/1.1 200 OK

content-type: application/json

date: Fri, 25 Sep 2026 11:20:17 GMT

Content-Length: 3583

```
{"result":true,"status":200,"data":{"totalGroups":6,"successCount":6,"failCount":0,"results":[{"ysvDosyaNo":"PENTEST1402-06","result":true,"status":200,"data":{"adres":"ADRES","ay":2,"ilKodu":1,"ilceKodu":null,"sigortaSirketKodu":"045","sonOdemeTarihi":"2014-03-20","telefon":"8503999999","unvan":"ALLIANZ S  GORTA A.  .", "vkn":"8000013270","yil":2014,"ysvDosyaNo":"PENTEST1402-06","ysvTutarList":[{"menkulTipi":"MENKUL","alınanPrimTutari":88000,"iptalPrimTutari":2000,"vergiPrimTutari":86000,"vergiOrani":10,"odenecekVergi":86000},{menkulTipi":"GAYRIMENKUL","alınanPrimTutari":44000,"iptalPrimTutari":1000,"vergiPrimTutari":43000,"vergiOrani":10,"odenecekVergi":43000}]}},{ysvDosyaNo":"PENTEST1402-02","result":true,"status":200,"data":{"adres":"ADRES","ay":2,"ilKodu":6,"ilceKodu":null,"sigortaSirketKodu":"045","sonOdemeTarihi":"2014-03-20","telefon":"8503999999","unvan":"ALLIANZ S  GORTA A.  .", "vkn":"8000013270","yil":2014,"ysvDosyaNo":"PENTEST1402-02","ysvTutarList":[{"menkulTipi":"GAYRIMENKUL","alınanPrimTu
```

Uygulama #5:

HTTP İSTEK

PUT /sbm-declaration-services/api/v1/declarations/PENTEST1402-01 HTTP/1.1

Content-Type: application/json

User-Agent: bruno-runtime/4.2.0

X-User-Name: allianz

Content-Length: 470

Host: int-sc-uat-elementer.allianz.com.tr

Connection: close

```
{
  "sonOdemeTarihi": "2014-03-20",
  "ysvTutarList": [
    {
      "menkulTipi": "MENKUL",
      "alınanPrimTutari": 660000.0,
      "iptalPrimTutari": 14000.0,
      "odenecekVergi": 64600.0,
      "vergiOrani": 10,
      "vergiPrimTutari": 646000.0
    },
    {
      "menkulTipi": "GAYRIMENKUL",
      "alınanPrimTutari": 325000.0,
      "iptalPrimTutari": 7000.0,
      "odenecekVergi": 31800.0,
      "vergiOrani": 10,
      "vergiPrimTutari": 318000.0
    }
  ]
}
```

HTTP CEVAP

HTTP/1.1 200 OK



```
content-type: application/json
date: Fri, 25 Sep 2026 11:21:39 GMT
Content-Length: 40

{"result":true,"status":200,"data":true}
```

Uygulama #6:

HTTP İSTEK

```
GET /sbm-declaration-services/api/v1/declarations/PENTEST1402-01 HTTP/1.1
User-Agent: bruno-runtime/4.2.0
X-User-Name: allianz
Host: int-sc-uat-elementer.allianz.com.tr
Connection: keep-alive
Content-Length: 4
```

HTTP CEVAP

```
HTTP/1.1 200 OK
content-type: application/json
date: Fri, 25 Sep 2026 08:37:38 GMT
Content-Length: 555

{"result":true,"status":200,"data":{"adres":"ADRES","ay":2,"ilKodu":34,"ilceKodu":null,"sigortaSirketKodu":"045","sonOdemeTarihi":"2014-03-20","telefon":"8503999999","unvan":"ALLIANZ SİGORTA A.Ş.,"vkn":"8000013270","yil":2014,"ysvDosyaNo":"PENTEST1402-01","ysvTutarList":[{"menkulTipi":"GAYRİMENKUL","alinanPrimTutari":325000,"iptalPrimTutari":7000,"vergiPrimTutari":318000,"vergiOrani":10,"odenecekVergi":318000}]}
```

Çözüm/Öneri: Uygulama kimlik doğrulama ve oturum yönetimi ayarlarının kontrol edilmesi ve login sonrası bağlantı yapılması gereken tüm uygulamalara yetkisiz erişimlerin engellenmesi yararlı olacaktır. Eğer ilgili servislere tüm kullanıcıların erişmesi gerekli değil ise IP tabanlı kontroller ile filtreler tanımlanması faydalı olacaktır.

2.3 - Swagger API Dokümantasyon Sayfalarına Erişim

2

Kategori: Web Sunucu Yapılandırma Hatası ve Güvenlik Problemleri

Etki: Bilgi Açığa Çıkarma

Kök Neden: Yapılandırma Yönetimi

CVSSv3 Skoru: 5.3

Risk: Orta

Port: 443/TCP

int-sc-uat-elementer.allianz.com.tr - 10.70.52.91

Açıklama: Gerçekleştirilen kontrollerde test edilen sunucu üzerinde çalışan API kullanımına ilişkin örneklerin ve uygulama listesinin bulunduğu Swagger uygulamalarına erişim yapılabildiği tespit edilmiştir. Saldırganlar bu sayfaları kullanarak üretilecek istekler ve arka planda çalışan fonksiyonlar hakkında bilgi sahibi olabilirler.

No	Hostname / IP
1	int-sc-uat-elementer.allianz.com.tr

<https://int-sc-uat-elementer.allianz.com.tr/sbm-declaration-services/swagger-ui>
<https://int-sc-uat-elementer.allianz.com.tr/sbm-declaration-services/swagger-ui/api/api-docs/swagger-config>
<https://int-sc-uat-elementer.allianz.com.tr/sbm-declaration-services/swagger-ui/index.html>
<https://int-sc-uat-elementer.allianz.com.tr/sbm-declaration-services/swagger-ui/oauth2-redirect.html>



<https://int-sc-uat-elementer.allianz.com.tr/sbm-declaration-services/swagger-ui/swagger-initializer.js>
<https://int-sc-uat-elementer.allianz.com.tr/sbm-declaration-services/swagger-ui/swagger-ui-bundle.js>
<https://int-sc-uat-elementer.allianz.com.tr/sbm-declaration-services/swagger-ui/swagger-ui-standalone-preset.js>
<https://int-sc-uat-elementer.allianz.com.tr/sbm-declaration-services/swagger-ui/api/api-docs>

Ekran Görüntüsü:

int-sc-uat-elementer.allianz.com.tr/sbm-declaration-services/swagger-ui/index.html#/Declaration%20Import/validate

SBM Declaration Services

sbm-declaration-services/swagger-ui/api-docs

Yangın Sigorta Vergisi (YSV) beyannamelerinin ESB üzerinden SBM'ye gönderilmesi, güncellenmesi ve sorgulanması.

Servers

https://int-sc-uat-elementer.allianz.com.tr/sbm-declaration-services - Generated server url

Declaration Import

YSV beyanname Excel yükleme (1. aşama)

POST /api/v1/declarations/upload YSV beyanname Excel'ini (.xlsx) yükle; geçerli satırları NEW olarak yazdır

Parameters Try it out Reset

Name	Description
X-User-Name string (header)	İşlemi yapan kullanıcı; DB'deki *_BY_USER kolonlarına yazılır. Yoksa SYSTEM.
X-Requester-Id-Type string (header)	İşlemi yapanın kimlik tipi: 1 = T.C. Kimlik No, 2 = VKN, 4 = Yabancı Kimlik No. Kimlik numarasıyla birlikte gönderilir; ikisi de yoksa şirket VKN'si kullanılır.
X-Requester-Id-No string (header)	İşlemi yapanın kimlik numarası (TCKN/YKN 11, VKN 10 hane).

Request body multipart/form-data

Çözüm/Öneri: Bu tip dokümantasyon sayfaları, uygulamalar kullanıma açılmadan önce sistem üzerinden kaldırılmalıdır. swagger-ui.html sayfalarını kaldırmak için aşağıda belirtilen işlemler uygulanabilir.

```
springdoc.swagger-ui.enabled=false
```

Spring tabanlı uygulamalarda daha fazla bilgiye aşağıdaki linkten ulaşılabilir.

<https://springdoc.org/#disabling-the-swagger-ui>

2.4 - Web Sunucu Default Hata Mesajları

1

Kategori: Web Sunucu Yapılandırma Hatası ve Güvenlik Problemleri
Etki: Bilgi Açığa Çıkarma
Kök Neden: Yapılandırma Yönetimi
CVSSv3 Skoru: 5.3
Risk: Düşük
Port: 443/TCP

int-sc-uat-elementer.allianz.com.tr - 10.70.52.91



Açıklama: Web sunucuları çeşitli hata durumları için farklı hata sayfaları görüntülemektedirler. Örneğin 404 hata mesajı istenen kaynak hedef sistem üzerinde bulunmuyor ise, 403 hata mesajı ise istenen kaynağa erişim sınırlandırılmış ise görüntülenmektedir. Saldırganlar web sunucularının ürettikleri bu mesajlardan yararlanarak sunucu üzerindeki kaynakları belirleyebilirler. Bunun dışında geçerli hata mesajları web sunucu ve işletim sistemi tipini belirlemek için de rahatlıkla kullanılabilirler.

No	Hostname / IP
1	int-sc-uat-elementer.allianz.com.tr

Tomcat hata mesajları ve benzeri 403, 404 gibi hata mesajlarının bilgi açığa çıkmasının engellenmesi amacıyla statik hata sayfalarına yönlendirilmesi tavsiye olunur.

HTTP İSTEK

```
GET /sbm-declaration-services/api/v1/declarations/files/..%2f%23 HTTP/1.1
User-Agent: bruno-runtime/4.2.0
X-User-Name: allianz
Host: int-sc-uat-elementer.allianz.com.tr
Connection: close
```

HTTP CEVAP

```
HTTP/1.1 400 Bad Request
content-type: text/html; charset=utf-8
content-language: en
content-length: 435
date: Fri, 25 Sep 2026 08:47:56 GMT

<!doctype html><html lang="en"><head><title>HTTP Status 400 â Bad Request</title><style type="text/css">body {font-family:Tahoma,Arial,sans-serif;} h1, h2, h3, b {color:white;background-color:#525D76;} h1 {font-size:22px;} h2 {font-size:16px;} h3 {font-size:14px;} p {font-size:12px;} a {color:black;} .line {height:1px;background-color:#525D76;border:none;}</style></head><body><h1>HTTP Status 400 â Bad Request</h1></body></html>
```

Ekran Görüntüsü:

HTTP Status 400 – Bad Request

Çözüm/Öneri: Web sunucuları kullanıma alınmadan önce 404, 403, 500 gibi hata durumları için ürettikleri hata mesajları veya sayfaları değiştirilmelidir. Bu işlemin nasıl yapılacağı ile ilgili bilgiler aşağıda sunulan linklerde yer almaktadır.

- Microsoft IIS 8.x/10x - <https://learn.microsoft.com/en-us/iis/configuration/system.webserver/httperrors/>
- Microsoft IIS 6.x - <https://www.microsoft.com/technet/prodtechnol/WindowsServer2003/Library/IIS/80cb8d8d-8fd8-4af5-bb3b-4d11fff3ab9c.msp?mfr=true>
- Microsoft IIS 7.x - [http://technet.microsoft.com/en-us/library/cc771076\(v=ws.10\).aspx](http://technet.microsoft.com/en-us/library/cc771076(v=ws.10).aspx)
- Apache - <http://httpd.apache.org/docs/2.2/custom-error.html>
- Apache Tomcat - <http://wiki.apache.org/tomcat/FAQ/Miscellaneous#Q6>

Bunun dışında web sunucu cevap başlığında yer alabilecek "Server", "X-Powered-By", "X-AspNetMvc-Version", "X-AspNet-Version" gibi başlıklara bakılarak zafiyet tahmini yapılması mümkündür. Bu nedenle söz konusu başlık bilgilerinin temizlenmesi de sunucu güvenliğini arttırıcı unsurlar arasındadır.



3. EKLER

3.1 – İLETİŞİM BİLGİLERİ

Genel:



İSTANBUL
Nida Kule Plaza,
Kozyatağı Mah.
Değirmen Sok. No:18
Kat:19 34742 Kozyatağı,
Kadıköy, İstanbul
+90 216 688 8182

ANKARA
ODTÜ Teknokent İkizler
Binası Üniversiteler Mah.
İhsan Doğramacı Bulvarı
No:35 B Blok Kat:106 800
Çankaya / Ankara
+90 312 210 1177

DUBAİ
SECURR ENT ME FZ LLC
214, Building 12, DIC
502318, UAE - Dubai
+9 9714 390 16 46-49

AMSTERDAM
Penetra Cyber Security
Strawinskylaan 411
1077XX Amsterdam
The Netherlands
+31(0)70-2045180

Raporu Hazırlayanlar:

Test Ekibi	Sertifika
Cihan ÖNCÜ - cihano@cyberwise.com	Kıdemli Sızma Testi Uzmanı
Raporu Hazırlayan	
Cihan ÖNCÜ - cihano@cyberwise.com	Kıdemli Sızma Testi Uzmanı
Raporu Kontrol Eden	
Fatih Özel - fatiho@cyberwise.com	Kıdemli Sızma Testi Uzmanı

Rapor Düzenleme Geçmişi:

SÜRÜM	TARİH	AÇIKLAMA	DÜZENLEYEN
0.1	25.09.2026	Taslak rapor şablonu oluşturma	Cihan ÖNCÜ
0.3	25.09.2026	Şablon düzenlemeleri ve bulgu eklemeleri	Cihan ÖNCÜ
0.5	25.09.2026	Bulgu eklemeleri ve düzenlemeler	Cihan ÖNCÜ
0.9	25.09.2026	Kalite Kontrol	Fatih Özel
1.0	25.09.2026	1.0 sürümünün hazırlanması	Cihan ÖNCÜ

3.2 – TAKİP EDİLEN YÖNTEMLER

Saldırı ve sızma testlerinin esas amacı, kuruma ait ağlar içinde, sadece özel sistemlerin veya Internet üzerinden herkesin erişimine açık durumda bulunan, sunucular, sistemler veya çeşitli teknolojiler kullanılarak geliştirilmiş uygulamalar üzerinde bulunabilecek muhtemel güvenlik açıklarını ve yapılandırma hatalarını kötü niyetli saldırganlardan önce ortaya çıkartmak ve gerekli önlemlerin alınmasına katkı sağlamaktır.

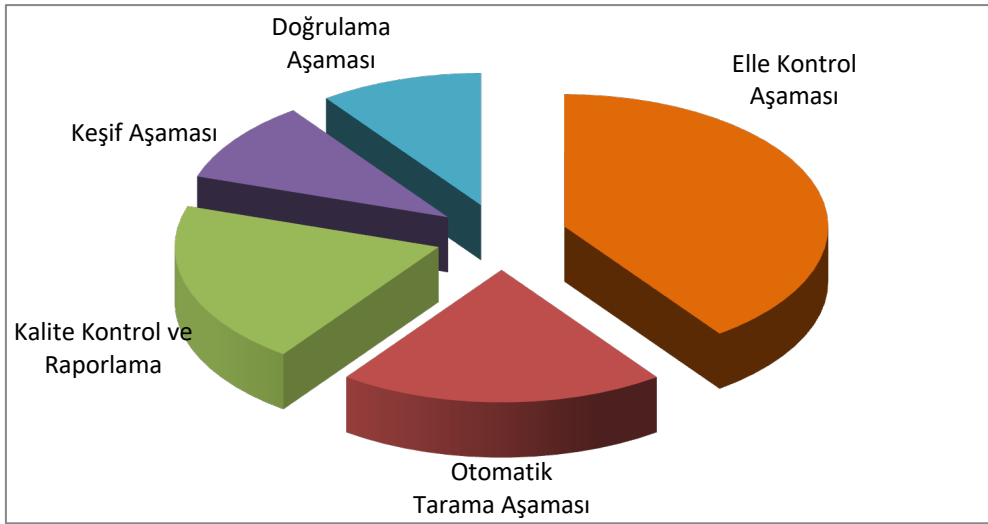
Sızma testlerinde takip edilen yöntemlerde [CREST Penetration Testing Guide](#) ve [OWASP Testing Guide](#) metodolojilerden faydalanılmıştır.

Bunu etkin bir şekilde sağlamak ve saldırı ve sızma testleri kapsamındaki hizmetlerimizi her defasında aynı yüksek kalite standardında gerçekleştirebilmek amacıyla yıllar süren çalışmaların sonucunda oluşturduğumuz yöntemleri takip ediyoruz. Bu yöntemler, yapılacak çalışmanın tipinden bağımsız olarak genel hatları ile benzerlik taşımaktadır. Yöntemlerin genel aşamalarının benzerliği Cyberwise kalite kontrol süreçlerinin de daha yüksek başarımla gerçekleştirilmesine olanak tanımaktadır. Tüm testler genellikle temel olarak aşağıdaki adımlarda gerçekleştirilmekte ve servis tipine göre hizmet detayları metodoloji bölümünde anlatılacağı şekilde detaylanmaktadır.



Bu adımların bir döngü halinde belirli periyotlar dahilinde çalıştırılması neticesinde daha etkin bir güvenlik kontrolü sağlanabilir.

Test yöntemlerinin ortak yönlerinden biri hatalı sonuçları en aza indirmek amacıyla çabanın ciddi bir kısmının elle tarama, kontrol ve doğrulama testlerine ayrılması ve sadece otomatik tarama araçlarından yararlanılmamasıdır. Cyberwise'i piyasada saldırı ve sızma testleri gerçekleştiren diğer firmalardan ayıran en önemli özelliklerden biri bu yöntemleri sıkı sıkıya takip etmemiz ve müşterilerimize otomatik tarama araçlarının verebileceğinin çok ötesinde bir hizmet vermemizdir. Cyberwise bu yöntemleri uygularken, sektör lideri firmaların lisanslı ürünlerinden, açık kaynak kodlu yazılımlardan ve kendi geliştirdiği yazılımlardan faydalanmaktadır. Cyberwise bünyesinde bu yöntemleri uygulayan mühendisler, CEH (Certified Ethical Hacker), CISSP (Certified Information Systems Security Professional) ve CISA (Certified Information Systems Auditor) gibi uluslararası geçerliliği olan sertifikalara ve her biri en az 5 yıl bilgi güvenliği deneyimine sahiptir. Cyberwise bu çalışmaların hiçbir aşamasını kesinlikle şirket bünyesi dışından sağlamamaktadır.



Aşağıda kurumunuz tarafından talep edilen sızma testleri için Cyberwise tarafından önerilen denetim servisleri ve servisler gerçekleştirilirken uzman ekibimizin takip ettiği metodoloji incelemenize sunulmuştur.

3.2.1 – İNTERNET GÜVENLİK DENETLEMESİ YÖNTEMİ

İnternet üzerinden erişilebilir kurum kaynaklarına (iletişim altyapısı, erişilebilir ağ ekipmanları DNS sunucular, FTP sunucuları, E-POSTA sunucuları, web sunucuları, güvenlik duvarı, SSLVPN, IPSECVPN sistemleri vb.), isteğe bağlı olarak değişik kullanıcı yetki profilleri ile(yetkili veya yetkisiz kullanıcı, müşteri, kurum, misafir kullanıcı hakları, vb.) değişik araçlar ve metodlar kullanılarak gerçekleştirilen ve bilinen muhtemel güvenlik açıklarını saldırganlardan önce keşfetmeyi amaçlayan denetim hizmetidir.

Bu çalışmada kurum tarafından belirtilen ağ blokları ve alan adları için keşif çalışması yapılarak, çalışma neticesinde aktif ve erişilebilir olduğu belirlenen tüm sistemlerin taranması hedeflenmektedir. Bu testler genel olarak aşağıda belirtilen adımlara uygun olarak gerçekleştirilmektedir.

1- Keşif Aşaması

Test edilecek sistemler hakkında aktif ve pasif yöntemler kullanılarak detaylı bilgi toplama aşamasıdır. Bu aşamada genel olarak aşağıdaki işlemler gerçekleştirilir.

- Değişik arama motorları kullanılarak kurum sistemleri hakkında bilgi toplama



- Ağ haritasının çıkartılması
- DNS ve Ters DNS araştırması ile bilgi toplama
- ISP/ASP Bilgileri
- Kontrol edilecek sistemlere ait DNS kayıtları, hostname bilgilerinin toplanması
- Erişilebilir Sistemlerin ve erişim yöntemlerinin belirlenmesi
- Açık, kapalı veya filtrelenmiş portların belirlenmesi
- Güvenlik duvarı üzerinde tanımlı Internet erişim kurallarının belirlenmesi
- Kullanılan diğer güvenlik cihazlarının ortaya çıkartılması ve etkinliklerinin belirlenmesi
- Açık portlar üzerinde çalışan uygulamaların belirlenmesi
- Yük dengeleme sistemlerinin belirlenmesi
- Çalışan servisler hakkında detaylı bilgi toplama
- Test edilecek işletim sisteminin, yama veya çekirdek seviyesinin belirlenmesi
- Yerel ağ IP adreslerinin çıkartılması

2- Otomatik Güvenlik Taraması

Bu aşamada sunucu üzerinde çalıştığı belirlenen servisin tipine göre en ideal araçlar kullanılarak bilinen güvenlik açıklarının tespit edilmesi için otomatik güvenlik taraması gerçekleştirilmektedir. Bu aşamada değişik araçlardan toplanan bilgiler bir sonraki aşamada gerçekleştirilecek detaylı kontroller için kaynak olarak kullanılmaktadır. Bu aşamada genel olarak aşağıdaki işlemler gerçekleştirilmektedir.

- Bilinen güvenlik açıklarının değişik araçlar kullanılarak kontrol edilmesi
- Açık servislere yönelik detaylı kontroller ve güvenlik taramaları
- DNS, E-POSTA Servisleri (SMTP,POP3,IMAP), Firewall, VPN, WEB gibi yaygın servislere yönelik özel kontroller ve bu servislere yönelik zafiyetleri belirleme
- Uygulama ve servislerin bilinen açıklar için güvenlik arşiv siteleri kullanılarak kontrolü
- Web sunucuları, veri tabanı, SAP, SCADA gibi sistemlerin özel araçlar ile otomatik olarak kontrol edilmesi
- Uzaktan yönetim servislerine yönelik detaylı kontroller
- Eğer istenirse deneme-yanılma yöntemi kullanılarak parola tahmin kontrolleri
- Bilinen, basit veya üretici tarafından atanmış ilk parolaların kontrolü
- Güvenlik duvarına ve diğer kurum güvenlik sistemlerine yönelik kontroller ve testler

3- Elle Kontrol Aşaması

Otomatik kontrol aşamasında tespit edilen problemlerin gerçekten sistemler üzerinde var olup olmadığının Cyberwise uzmanları tarafından kontrol edildiği aşamadır. Bu aşamada amaç hatalı sonuçların en aza indirilerek hazırlanacak raporun en doğru sonuçları yansıtacak şekilde üretilmesini sağlamaktır.

Otomatik tarama araçlarının gözden kaçırabileceği veya tespit edemeyeceği sorunlar da bu aşamada denetlenir.

4- Raporlama

Elde edilen sonuçların doğru, anlaşılır ve teknik detayları ile birlikte sunulmasıdır. Hazırlanan raporlar firmanın bulunduğu risk seviyesi, bu riskleri nasıl minimuma indireceği gibi yönetimi ilgilendiren bilgileri kapsayacağı gibi, bulunan açıkların ne olduğu, bu açık kullanılarak neler yapılabileceği ve açıkların nasıl kapatılacağı anlatıldığı teknik detayları da içerecektir. Raporlar elektronik ve basılı olarak tercih edilen dilde sunulacaktır.

5- Doğrulama Aşaması

Önceki aşamalarda tespit edilen ve sunulan güvenlik açıklarının firma tarafından kapatılması sonrasında eksiklerin ortaya konulması amacıyla gerçekleştirilen güvenlik taramasıdır. Bu tarama çalışmasında sadece ilk çalışmada tespit edilen güvenlik açıklarının halen sistem üzerinde var olup olmadığı kontrol edilmektedir.

3.2.2 – WEB UYGULAMASI GÜVENLİK DENETLEMESİ YÖNTEMİ



Web tabanlı uygulamalar, diğer ağ uygulamaları ile karşılaştırıldığı zaman karmaşık yapıları, kullanılabilecek uygulamaların çeşitliliği ve değişkenliği sebebi ile daha gelişmiş yöntemler kullanılarak, HTTP protokolüne yönelik uygulama tabanlı kontroller ile değerlendirilmelidirler. Web uygulamasına yönelik güvenlik testlerinde temel amaç, Internet/Intranet üzerindeki sıradan haklara sahip bir kullanıcı ile, web uygulaması ve onun kullandığı bileşenlerin açıklarından yararlanarak, erişimi engellenmiş, izin verilmeyen veya gizli bilgilere erişim ile web uygulaması üzerinde daha geniş yetkilere sahip olmaktır. Bu işlemler gerçekleştirilirken aşağıdaki adımlar takip edilmektedir.

1- Keşif Aşaması

Test edilen sunucuya ait erişim bilgilerinin tespit edilmesi, DNS sorgulaması, web uygulamasının çalıştığı portların tespiti, sunucu ve uygulama sürümlerinin belirlenmesi ve web site haritasının çıkarılması gibi işlemler bu aşamada gerçekleştirilmektedir. Bu aşamada elde edilmesi hedeflenen bilgiler aşağıda yer almaktadır.

- Web uygulaması çalışan portların belirlenmesi
- Aynı sunucu üzerinde çalışan farklı web siteleri ve uygulamaların tespiti
- Web sunucu sürüm bilgilerinin tespiti
- SSL Sertifika bilgilerinin çıkartılması
- Sunucu üzerinde çalışan uygulamaların belirlenmesi
- Değişik arama motorları kullanılarak test edilen sistem hakkında bilgi toplamak ve kritik bilgilere erişim (Googling)
- Arama motorları ve değişik online sistemler kullanılarak uygulama hakkında kayıt altına alınmış olabilecek önemli bilgileri toplama
- Sunucu tarafından desteklenen metot ve encoding mekanizmalarının belirlenmesi
- Taranacak web site haritasının çıkarılması.
- Statik ve dinamik uygulamaların belirlenmesi

2- Statik Tarama Aşaması

Bu aşamada web sunucusunun ve kullanılan uygulamaların bilinen açıklara karşı standart tarama araçları, scriptler ve fuzzing adı verilen yöntemler ile kontrol edilmesi gerçekleştirilmektedir. Aşağıda bu aşamada gerçekleştirilen işlemler aşağıda listelenmiştir.

- Web sunucusunun standart tarama araçları ile kontrol edilmesi
- Sunucu tipinin belirlenmesi ve sunucu tipine göre mevcut sorunların ortaya çıkartılması
- Bilinen güvenlik açıklarının tespit edilmesi
- Kullanılan dizinlerin tespiti
- Sunucu yapılandırma hatalarının belirlenmesi
- Dizin erişim haklarının kontrolü
- Dizin içerik listeleme problemlerinin belirlenmesi
- Dizin atlatma problemlerinin tespiti
- Web sunucusu hata denetim mekanizmasının kontrol edilmesi
- İlk kurulum sonrası uygulama veya sunucu tarafından yüklenen web sayfası, izin ve uygulamaların belirlenmesi
- Yüklü sunucu bileşenleri ve uzantıların belirlenmesi
- Sunucunun desteklediği metotların belirlenmesi ve zararlı metotların kontrolü
- WEBDAV kontrolleri
- CGI problemlerinin belirlenmesi
- Kullanılan uygulama framework'üne yönelik kontroller
- Sunucu üzerindeki kritik bilgilere web üzerinden erişim testleri
- Bilinen dosya ve uygulama isimlerinin taranması
- Yedek, kopya veya test amaçlı kullanılan sayfa ve uygulamaların belirlenmesi
- Site içeriği ile ilgili olmadığı düşünülen sayfa ve uygulamaların belirlenmesi
- Deneme-Yanılma tahmin saldırıları

3- Dinamik Tarama Aşaması



Web uygulamasının ve sunucunun, web uygulamasına ve belirlenen sunucunun tipine yönelik hazırlanmış özel güvenlik araçları ve elle kontrol edilmesi bu aşamada gerçekleştirilmektedir. Bu aşamada aşağıda belirtilen güvenlik açıklarının tespit edilmesi amaçlanmaktadır.

- Veri Girdi ve Çıktı denetimleri
- Uygulamaya yönelik DoS kontrolleri
 - Uygulama stres testleri
 - Parametre Buffer Overflow testleri
 - Format String Problemlerini belirlemeye yönelik testler
 - Uygulama üzerinden kontrolsüz veri yollama testleri
 - Otomatik ve çok sayıda veri yollama testleri
- Uygulama Hata Mesajlarının Kontrolleri
 - Detaylı Bilgi açığa çıkmasına neden olan hatalar
 - Yol Bilgileri
 - Veri tabanı hata mesajları
 - Uygulama sürüm bilgileri
- Parametre kontrolleri
 - HTTP başlığındaki bilgileri bozarak gerçekleştirilen kontroller
 - Parametre bilgileri ile oynanarak gerçekleştirilen kontroller
 - Form ile yollanan bilgileri bozarak gerçekleştirilen kontroller
 - URL içindeki bilgileri bozarak yapılan testler
 - Cookie bilgilerini değiştirerek gerçekleştirilen
 - SessionID bilgileri ile oynanarak gerçekleştirilen testler
 - Parametreler ile oynanarak debug ve detaylı loglama mekanizmalarının ortaya çıkarılması
 - Hidden Field denetimleri
- HTML içindeki açıklama alanlarından kritik bilgilere erişim testleri
- Yetkilendirme kontrolleri
 - Yetkilendirme mekanizmasını devre dışı bırakmaya yönelik testler
 - Default kullanıcı hesaplarının belirlenmesi
 - Kullanılan şifre kalitesinin belirlenmesi
 - Şifre sıfırlama ve parola hatırlatma mekanizmalarının güvenliğine ilişkin kontroller
- Oturum yönetimi kontrolleri
 - Hesap kilitleme politikalarının belirlenmesi
 - Kullanıcı hesaplarını belirlemeye izin veren hata mesajlarının kontrolü
 - Oturum zaman aşımı kontrolleri
 - Eş zamanlı oturum açma kontrolleri
 - Session Hijacking'e izin veren zayıflıkların kontrolü
 - Session Fixation Kontrolleri
 - Session Riding Kontrolleri
 - Session Replay Kontrolleri
 - Hak Yükseltme Kontrolleri
 - Farklı kullanıcılara ait bilgilere erişime yönelik kontroller
 - Oturum Belirticine(SessionID) Yönelik Kontroller
 - Oturum Belirticinin kalitesine yönelik kontroller
 - SessionID Secure Flag Kontrolleri
- Kritik form alanlarını değiştirmeye yönelik kontroller
- Veri İletim Güvenliği Kontrolleri
 - HTTP Protokolü üzerinden kritik bilgilere erişim
 - Erişilebilir web tabanlı yönetim arabirimleri
 - SSL Zayıf Cipher ver Sürüm Kontrolleri
- Uygulama ve Sunucu hata mesajı yayınlama kontrolleri
- Uygulama üzerinden komut enjekte etme kontrolleri
 - SQL, BLIND SQL
 - LDAP
 - XML
 - XQuery
 - Script
 - İşletim Sistemi Komutları



- SSI
- XPATH
- Null Byte
- E-Posta ve IMAP
- Second-Order
- Expression Language Injection
- PHP/ASP Kod çalıştırma/ekleme güvenlik problemleri
- Stored, Reflected ve Second-Order Cross Site Scripting (XSS) ve Cross Site Request Forgery (XSRF) kontrolleri
- DOM Tabanlı XSS problemlerini belirlemeye yönelik kontroller
- Uygulamanın geliştirildiği framework'e (Google GWT, Java ZK, vb.) özel kontroller
- Dosya Yükleme Uygulamalarının Kontrolü
 - Yapısal Dosya Kontrolü Yapılıp Yapılmadığının Denetlenmesi
 - İzin Verilen Dosya Uzantı Tiplerinin Kontrolü
 - Dosya Yüklenebilir Dizinlere Erişimlerin Kontrolü
 - Zararlı İçeriğe Sahip Dosya Yükleme İmkanının Kontrolü
- Spoofing Kontrolleri
 - Content Spoofing
 - Frame Spoofing
 - Link Spoofing
 - Web Site Spoofing
- Kontrolsüz yönlendirme mekanizmalarına yönelik kontroller
- HTTP Response Splitting kontrolleri
- HTTP Response Injection kontrolleri
- XML Kontrolleri
 - XXE (XML External Entity) Saldırıları
 - XML DoS Kontrolleri (XML Bomb)
 - XML Garbage Kontrolleri
 - XML Standart Kontrolleri (Standart Soups)
- Captcha Kontrolleri
 - Zayıf Captcha Kontrolleri
 - Captcha Replay Zayıflıklarının Kontrolü
 - Captcha Binary Decode Kontrolleri
- Kaynak kodu görüntüleme kontrolleri
- Dizin atlama yöntemi ile işletim sistemi üzerindeki dosyalara erişim kontrolleri
- Uzak veya yerel dosya kaynak kodu ekleme kontrolleri
 - Remote File Inclusion (RFI)
 - Local File Inclusion (LFI)
 - Malicious File Inclusion (MFI)
- Uygulama tarafından kullanılan veya uzaktan eklenen scriptlerin güvenliğine yönelik kontroller
- Flash ve FLEX tabanlı uygulamalara yönelik kontroller
 - Flashvars XSS problemleri
 - Genel XSS sorunlarını belirlemeye yönelik kontroller
 - Flash kaynak kodlarının obfuscation kontrolleri
 - Kaynak kodlarının kritik bilgiler içerip içermediğine yönelik kontroller
 - İstemci tabanlı kontrollerin devre dışı bırakılması durumunda ortaya çıkabilecek sorunlara yönelik kontroller
 - Harici sistemlere erişime veya bu sistemlerden dosya açmaya izin veren uygulamaların güvenliğine ilişkin kontroller
 - Debug ve hata mesajları gibi bilgi sızmasına neden olabilecek yapılandırma hatalarının belirlenmesi
- Uygulama tarafından kullanılacak muhtemel web servislerinin güvenliğine ilişkin kontroller
- Uygulama tarafından alınmış hatalı filtreleri ortaya çıkartma
- Servis dışı bırakma saldırılarında kullanılacak uygulamaları tespit edilmesi
- Değişik encoding yöntemleri kullanarak sunucu veya uygulama tarafından sağlanan güvenlik denetimlerinin devre dışı bırakma testleri

4- Elle Kontrol Aşaması



Otomatik tarama sonrasında elde edilen sonuçların ve tespit edilen güvenlik açıklarının Cyberwise uzmanları tarafından sunucu üzerinde gerçekten var olup olmadığının tespit edilmesi aşamasıdır. Bu aşama hatalı sonuçların minimuma indirilmesi ve raporların en doğru sonuçları yansıtması açısından oldukça önemlidir. Bu aşamada;

- Hatalı sonuçların ayıklanması
- Otomatik web uygulama tarama araçlarının belirleyemeyeceği problemler için gerekli kontrollerin uzmanlar tarafından yapılması
- Uygulamaya yollanan isteklere alınan cevaplardan direk olarak belirlenemeyecek (second order veya stored) sorunların ortaya çıkartılmasına yönelik kontroller
- Varlığı tespit edilmiş güvenlik açıklarından yararlanmaya çalışma
- Sunucuyu ele geçirmeye yönelik testler gerçekleştirme
- Web sunucusu üzerinden arka plandaki veri tabanına erişim sağlama
- Ele geçirilen sunucu üzerinden diğer sistemlere veya yerel ağa sızma

gibi işlemler gerçekleştirilmektedir.

Otomatik tarama araçlarının gözden kaçırabileceği, uygulamaya yönelik değişik yöntemler kullanılarak elle veya Cyberwise ekibinin geliştirdiği tarama araçları ve scriptler aracılığı ile sistemlerin kontrol edildiği aşamadır.

5- Raporlama

Elde edilen sonuçların doğru, anlaşılır ve teknik detayları ile birlikte sunulmasıdır. Hazırlanan raporlar firmanın bulunduğu risk seviyesi, bu riskleri nasıl minimuma indireceği gibi yönetimi ilgilendiren bilgileri kapsayacağı gibi, bulunan açıkların ne olduğu, bu açık kullanılarak neler yapılabileceği ve açıkların nasıl kapatılacağı anlatıldığı teknik detayları da içerecektir. Raporlar elektronik ve basılı olarak tercih edilen dilde sunulacaktır.

6- Doğrulama Taraması

Önceki aşamalarda tespit edilen ve sunulan güvenlik açıklarının firma tarafından kapatılması sonrasında eksiklerin ortaya konulması amacıyla gerçekleştirilen güvenlik taramasıdır. Bu tarama çalışmasında sadece ilk çalışmada tespit edilen güvenlik açıklarının halen sistem üzerinde var olup olmadığı kontrol edilmektedir.

Cyberwise Siber Güvenlik Tic. A.Ş.
Ticari Sicil No: 159433

Cyberwise Bilişim Hiz. Tic. A.Ş
Ticari Sicil No: 703584



İSTANBUL

Nida Kule Plaza ,
Kozyatağı Mah.
Değirmen Sok. No:38
Kat:19 34742 Kozyatağı,
Kadıköy, İstanbul
+90 216 688 8182

ANKARA

ODTÜ Teknokent İkizler
Binası Üniversiteler Mah.
İhsan Doğramacı Bulvarı
No:35 B Blok Kat:106 800
Çankaya / Ankara
+90 312 210 1177

DUBAI

SECURR ENT ME FZ LL C
214, Building 12, DIC
502318, UAE - Dubai
+9 9714 390 16 46-49

AMSTERDAM

Penetra Cyber Security
Strawinskylaan 411
1077XX Amsterdam
The Netherlands
+31(0)70-2045180